

RELATÓRIO TÉCNICO

Segurança de Sistemas Operacionais

Estudo de Caso: Autenticação Fraca e Exposição de Credenciais no Histórico de Comandos

Laboratório prático baseado no módulo de Introdução à Segurança de Sistemas Operacionais — TryHackMe

Cenário: avaliação de segurança autorizada (teste de penetração) em ambiente de laboratório

Agosto de 2026

Sumário

1. Contexto e Objetivo
 2. Fundamentos: Hardware, Software e Sistema Operacional
 3. Panorama de Mercado dos Sistemas Operacionais
 4. A Tríade da Segurança da Informação (CIA)
 5. Vulnerabilidades Comuns: Senhas Fracas
 6. Acesso Inicial via Senha Fraca
 7. Escalonamento de Privilégios via Histórico de Comandos
 8. Comandos Utilizados
 9. Recomendações de Mitigação
 10. Conclusão
-

1. Contexto e Objetivo

Este relatório documenta um laboratório introdutório de segurança de sistemas operacionais, conduzido em ambiente controlado e autorizado (TryHackMe), simulando uma avaliação de segurança contratada por um cliente fictício. O objetivo foi demonstrar, na prática, como falhas simples e comuns — senhas fracas e reaproveitadas, e exposição acidental de credenciais — podem ser exploradas por um agente malicioso para obter acesso não autorizado a um sistema e escalar privilégios até o nível de administrador.

Antes de discutir a exploração em si, o laboratório revisita conceitos fundamentais: a relação entre hardware, software e sistema operacional, a tríade da segurança da informação (CIA) e as três vulnerabilidades mais comuns em ambientes reais: autenticação fraca, permissões de arquivo mal configuradas e programas maliciosos. O foco prático deste exercício foi a primeira delas.

Natureza do exercício

Toda a atividade foi realizada em uma máquina de laboratório isolada, disponibilizada especificamente para fins educacionais, reproduzindo um cenário de teste de penetração autorizado — nunca em sistemas de terceiros sem consentimento.

2. Fundamentos: Hardware, Software e Sistema Operacional

Hardware refere-se a todos os componentes físicos de um computador: tela, teclado, memória, processador (CPU) e a placa-mãe, que interliga todas as demais peças. Sozinho, o hardware é inútil — é o sistema operacional (SO) que atua como camada intermediária entre o hardware e os programas que utilizamos no dia a dia, como navegadores e aplicativos de mensagens, permitindo que eles acessem os recursos da máquina de forma controlada.

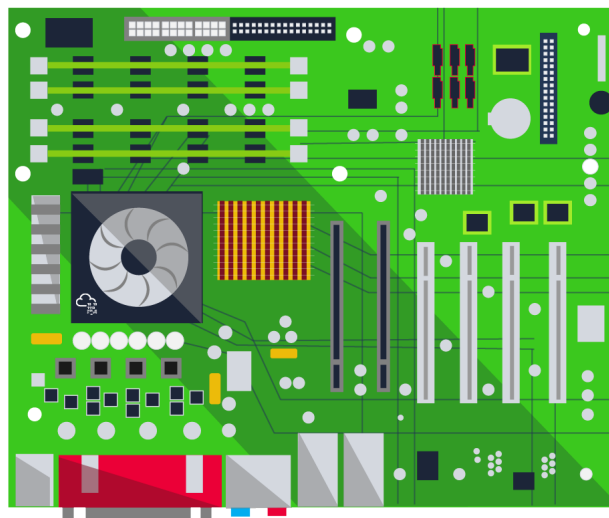


Figura 1 — Componentes de uma placa-mãe: CPU, chips de memória e slots de expansão, o núcleo físico de qualquer computador.

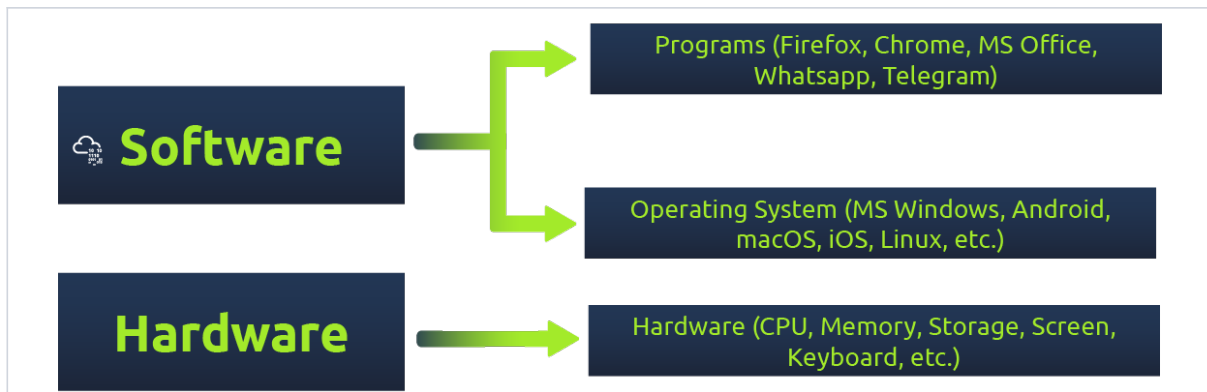


Figura 2 — Relação entre hardware, sistema operacional e programas: aplicativos como navegadores e mensageiros são executados sobre o SO, que por sua vez gerencia o acesso ao hardware.

3. Panorama de Mercado dos Sistemas Operacionais

Sistemas operacionais existem para diferentes finalidades: uso pessoal (Windows, macOS), dispositivos móveis (Android, iOS) e servidores (Windows Server, IBM AIX, Oracle Solaris). O Linux se destaca por ser utilizado tanto em computadores pessoais quanto em servidores — motivo pelo qual é amplamente adotado por equipes de segurança.

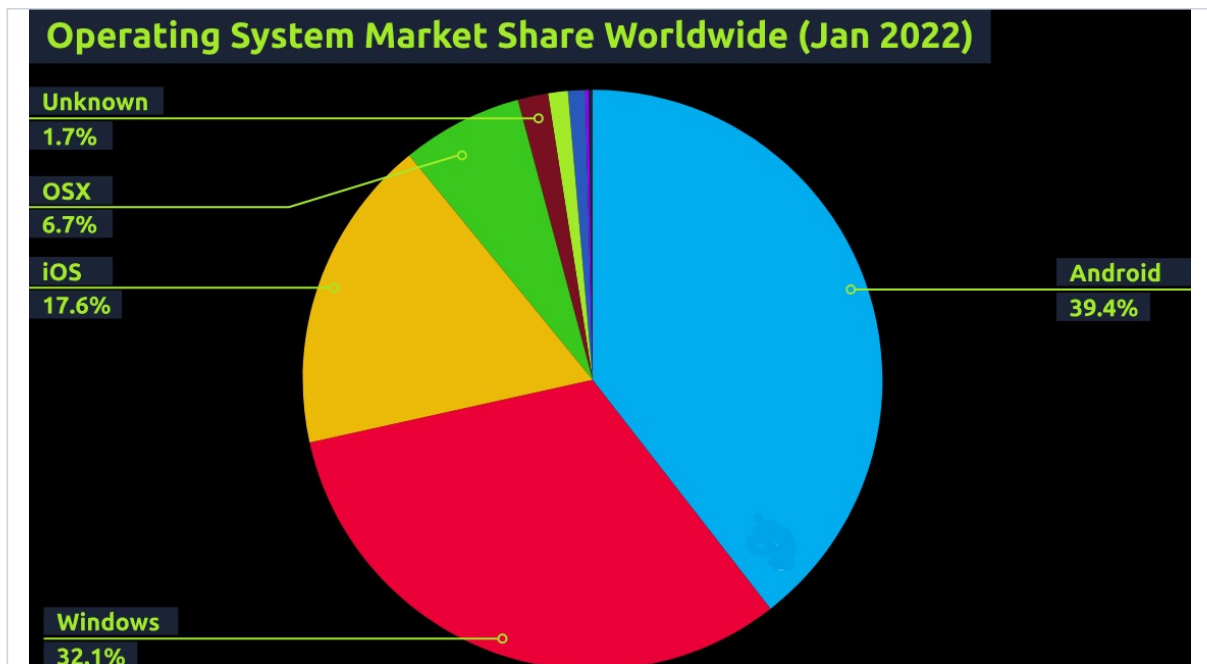


Figura 3 — Participação de mercado dos sistemas operacionais usados para navegação na internet (Statcounter, janeiro de 2022): Android lidera com 39.4%, seguido por Windows (32.1%) e iOS (17.6%).

4. A Tríade da Segurança da Informação (CIA)

Smartphones e computadores armazenam grandes volumes de dados sensíveis — conversas privadas, fotos, e-mails, senhas salvas e aplicativos bancários. Proteger essas informações significa garantir três propriedades fundamentais, conhecidas como a tríade CIA:



Figura 4 — A tríade CIA: Confidencialidade, Integridade e Disponibilidade, os três pilares da segurança da informação.

Parâmetro	Valor
Confidencialidade	Garantir que informações privadas e sigilosas estejam acessíveis apenas a pessoas autorizadas.
Integridade	Garantir que arquivos não sejam adulterados, seja em repouso ou durante a transferência pela rede.
Disponibilidade	Garantir que sistemas e dados estejam acessíveis sempre que forem legitimamente necessários.

5. Vulnerabilidades Comuns: Senhas Fracas

Entre as vulnerabilidades mais exploradas por agentes maliciosos estão a autenticação fraca, permissões de arquivo mal configuradas e programas maliciosos. Este laboratório focou na primeira: como senhas simples, previsíveis ou reaproveitadas em múltiplos serviços comprometem toda a segurança de uma conta.

A autenticação pode se basear em algo que você sabe (senha ou PIN), algo que você é (biometria) ou algo que você possui (código enviado por SMS). Como senhas continuam sendo o método mais comum, também são as mais atacadas. O NCSC (National Cyber Security Centre) publica anualmente uma lista das senhas mais usadas no mundo — e, conseqüentemente, mais fáceis de adivinhar:

#	Senha	#	Senha
1	123456	11	1234567890
2	123456789	12	123123
3	qwerty	13	000000
4	password	14	iloveyou
5	111111	15	1234
6	12345678	16	1q2w3e4r5t

#	Senha	#	Senha
7	abc123	17	qwertyuiop
8	1234567	18	123
9	password1	19	monkey
10	12345	20	dragon

Sequências numéricas (123456, 12345678), palavras de dicionário (password, iloveyou, monkey, dragon) e padrões de teclado (qwerty, qwertyuiop, 1q2w3e4r5t) dominam a lista — evidenciando que senhas 'complexas na aparência' nem sempre são difíceis de adivinhar.

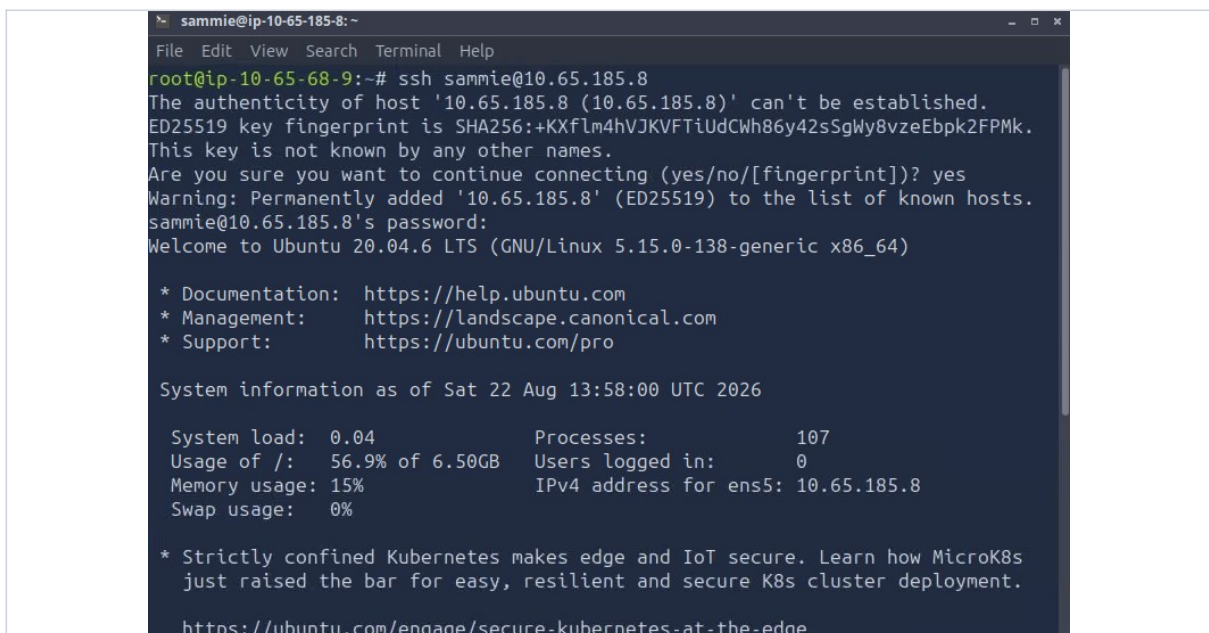
6. Acesso Inicial via Senha Fraca

6.1 Reconhecimento

Durante uma visita ao escritório do cliente fictício, foi observado um post-it colado em um monitor com as palavras 'sammie' e 'dragon' — um nome de usuário e uma possível senha, deixados à vista de qualquer pessoa que passasse pelo local. Esse tipo de falha, embora não seja técnica, é uma das formas mais comuns de vazamento de credenciais em ambientes corporativos reais.

6.2 Conexão SSH e autenticação

A partir do terminal do AttackBox, foi executado o comando `ssh sammie@10.65.185.8` para tentar acessar remotamente a máquina de laboratório usando o usuário e a senha observados. No primeiro acesso a um novo servidor, o SSH solicita a confirmação da autenticidade da chave do host, respondida com 'yes'.



```
sammie@ip-10-65-185-8: ~  
File Edit View Search Terminal Help  
root@ip-10-65-68-9:~# ssh sammie@10.65.185.8  
The authenticity of host '10.65.185.8 (10.65.185.8)' can't be established.  
ED25519 key fingerprint is SHA256:+KXflm4hVJKVFTiUdCWh86y42sSgWy8vzeEbpk2FPMk.  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '10.65.185.8' (ED25519) to the list of known hosts.  
sammie@10.65.185.8's password:  
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-138-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/pro  
  
System information as of Sat 22 Aug 13:58:00 UTC 2026  
  
System load:  0.04          Processes:      107  
Usage of /:   56.9% of 6.50GB  Users logged in:  0  
Memory usage: 15%          IPv4 address for ens5: 10.65.185.8  
Swap usage:   0%  
  
* Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s  
just raised the bar for easy, resilient and secure K8s cluster deployment.  
  
https://ubuntu.com/engage/secure-kubernetes-at-the-edge
```

Figura 5 — Conexão SSH bem-sucedida como sammie: confirmação da autenticidade do host e banner de boas-vindas do Ubuntu 20.04.6 LTS, exibindo informações do sistema.

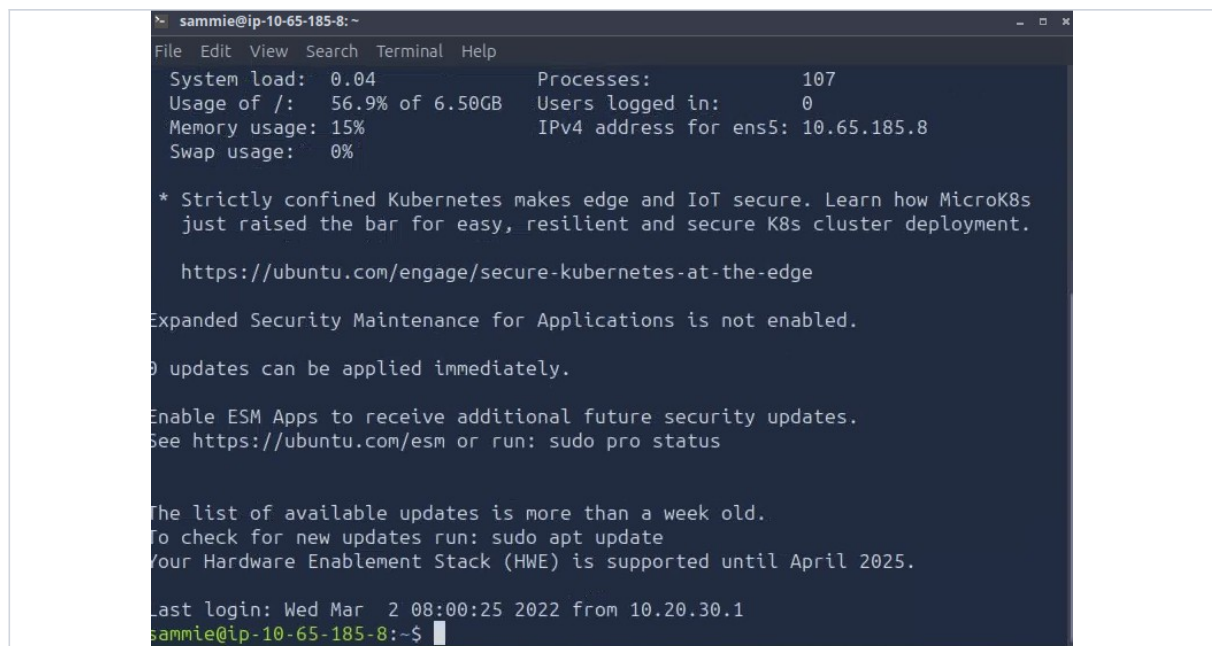
A terminal window titled 'sammie@ip-10-65-185-8: ~' displays system statistics: System load: 0.04, Processes: 107, Usage of /: 56.9% of 6.50GB, Users logged in: 0, Memory usage: 15%, IPv4 address for ens5: 10.65.185.8, and Swap usage: 0%. It also shows a message about MicroK8s security, a link to a Ubuntu article, and information about Ubuntu's security maintenance. At the bottom, it shows the last login time: 'Wed Mar 2 08:00:25 2022 from 10.20.30.1' and the prompt 'sammie@ip-10-65-185-8:~\$'.

Figura 6 — Banner completo pós-login, com uso de disco, memória, processos ativos e data do último acesso — confirmando que o acesso foi estabelecido com sucesso.

6.3 Confirmação de acesso e coleta inicial

Com a sessão ativa, o comando `whoami` confirmou a identidade do usuário conectado (`sammie`). Em seguida, `ls` revelou os arquivos presentes no diretório pessoal, e o comando `cat` foi usado para ler o conteúdo do arquivo `draft.md` — que, de forma irônica, alertava sobre os riscos de reaproveitar senhas entre diferentes serviços.

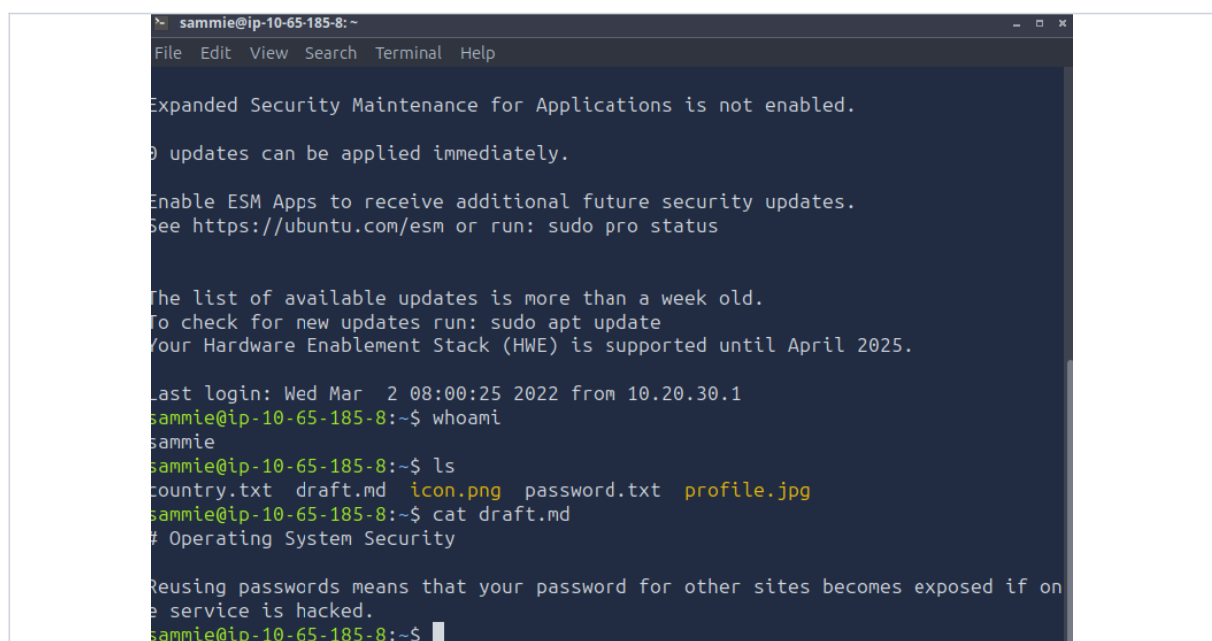
A terminal window shows the user `sammie` running `whoami` and `ls`. The output of `ls` lists: `country.txt draft.md icon.png password.txt profile.jpg`. Then, `cat draft.md` is run, displaying a warning about reusing passwords: '# Operating System Security' followed by 'Reusing passwords means that your password for other sites becomes exposed if one service is hacked.' The prompt is 'sammie@ip-10-65-185-8:~\$'.

Figura 7 — Confirmação de identidade (`whoami`), listagem de arquivos (`ls`) e leitura do arquivo `draft.md`, que alertava sobre os riscos da reutilização de senhas.

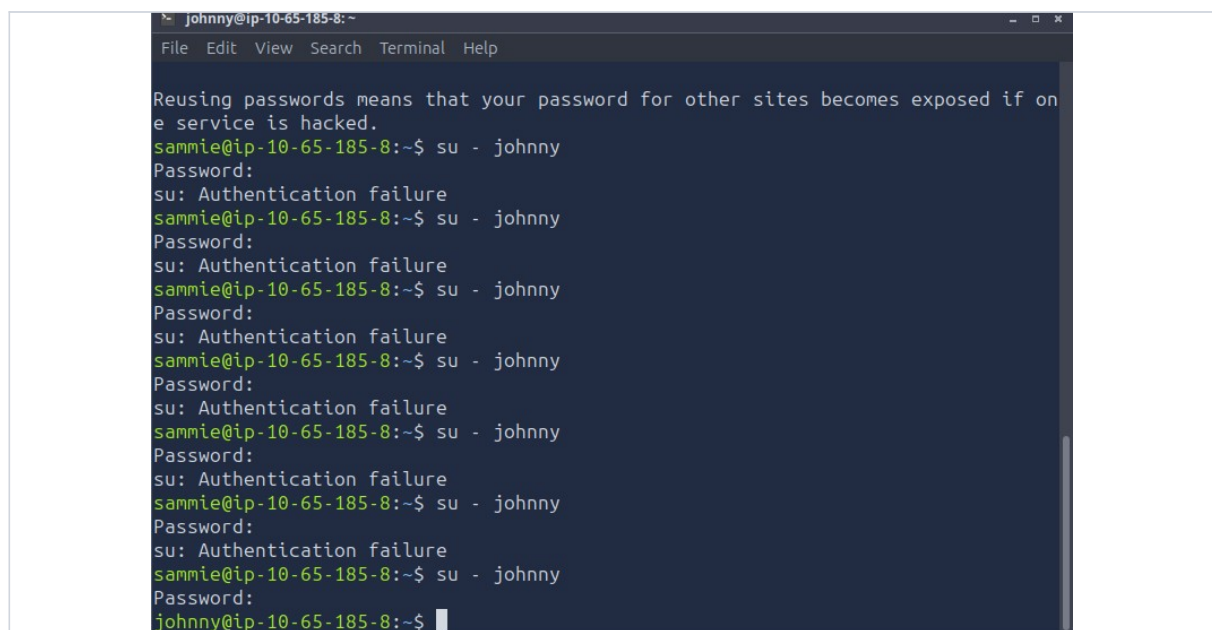
Achado

O próprio arquivo `draft.md` do usuário comprometido continha uma nota sobre segurança de senhas — um lembrete de que ter conhecimento teórico sobre boas práticas não substitui aplicá-las na prática.

7. Escalonamento de Privilégios via Histórico de Comandos

7.1 Movimentação lateral para outro usuário

Com acesso à conta de `sammie`, o próximo passo foi tentar alcançar outro usuário do sistema, `johnny`, por meio do comando `su - johnny`. Após diversas tentativas de senha sem sucesso ('Authentication failure'), a troca de usuário foi finalmente bem-sucedida.

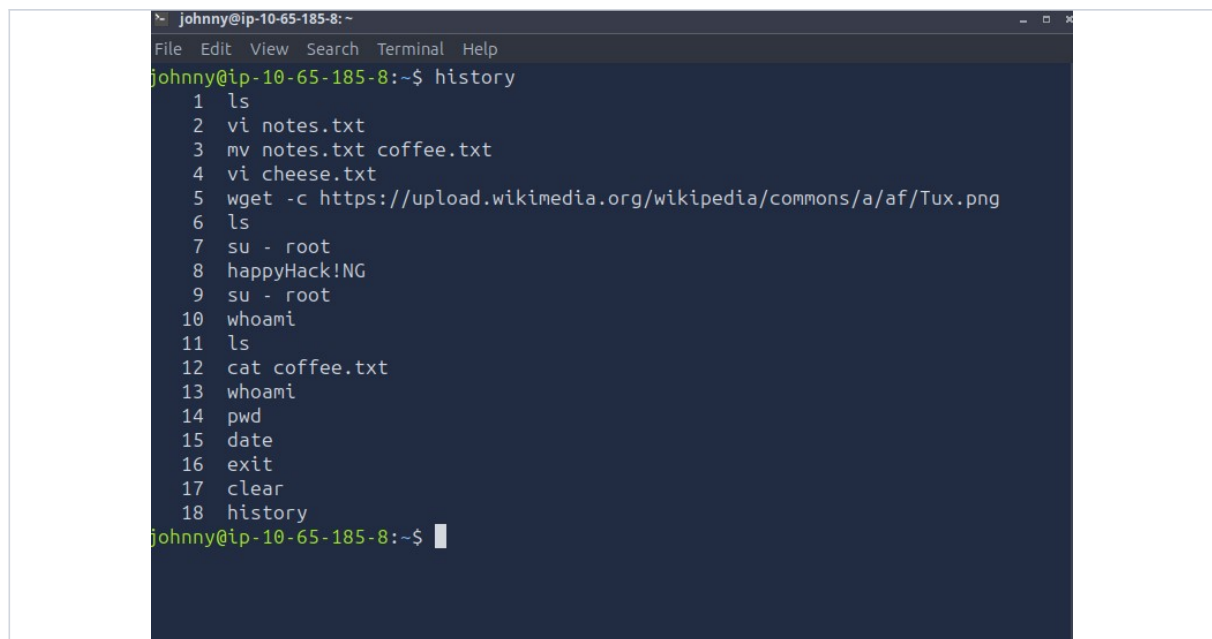


```
johnny@ip-10-65-185-8: ~  
File Edit View Search Terminal Help  
  
Reusing passwords means that your password for other sites becomes exposed if on  
e service is hacked.  
sammie@ip-10-65-185-8:~$ su - johnny  
Password:  
su: Authentication failure  
sammie@ip-10-65-185-8:~$ su - johnny  
Password:  
su: Authentication failure  
sammie@ip-10-65-185-8:~$ su - johnny  
Password:  
su: Authentication failure  
sammie@ip-10-65-185-8:~$ su - johnny  
Password:  
su: Authentication failure  
sammie@ip-10-65-185-8:~$ su - johnny  
Password:  
su: Authentication failure  
sammie@ip-10-65-185-8:~$ su - johnny  
Password:  
su: Authentication failure  
sammie@ip-10-65-185-8:~$ su - johnny  
Password:  
johnny@ip-10-65-185-8:~$
```

Figura 8 — Múltiplas tentativas de troca para o usuário `johnny` via `su`, com falhas de autenticação sucessivas até a obtenção de acesso.

7.2 Descoberta de senha vazada no histórico

Já como `johnny`, o comando `history` revelou o histórico de comandos previamente executados nessa conta — incluindo comandos de edição e download de arquivos. Entre eles, uma linha continha aparentemente uma senha (`happyHack!NG`) digitada como se fosse um comando: um erro comum, quando o usuário digita a senha antes que o prompt de autenticação apareça na tela, fazendo com que ela seja registrada em texto plano no histórico do shell.

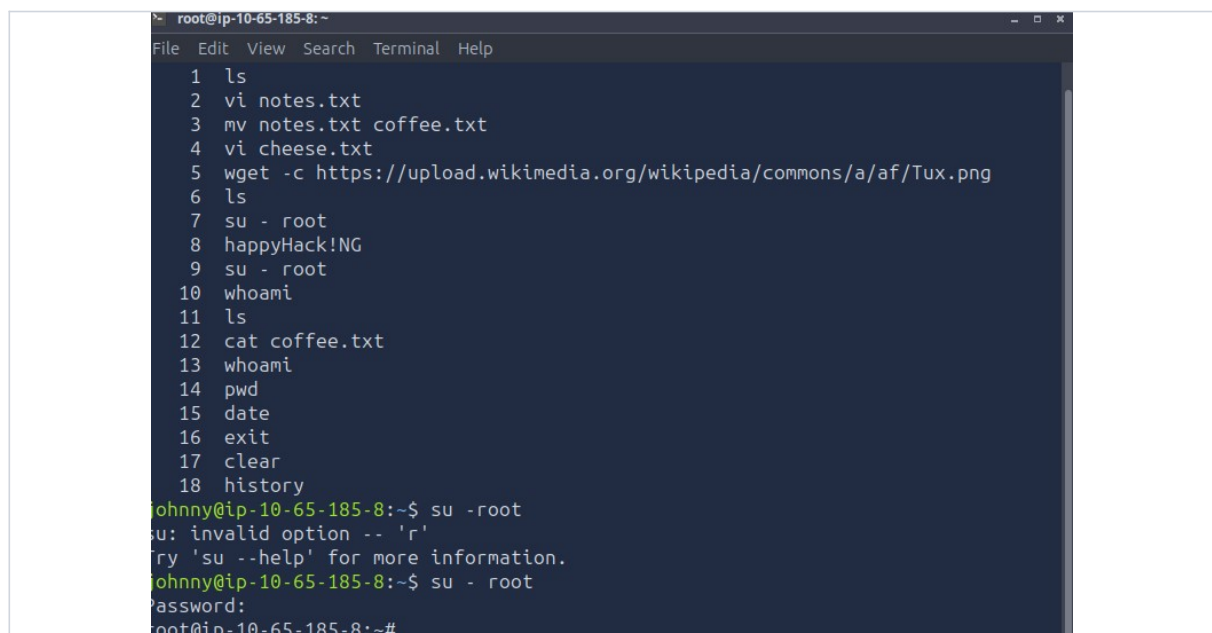


```
johnny@ip-10-65-185-8: ~  
File Edit View Search Terminal Help  
johnny@ip-10-65-185-8:~$ history  
1  ls  
2  vi notes.txt  
3  mv notes.txt coffee.txt  
4  vi cheese.txt  
5  wget -c https://upload.wikimedia.org/wikipedia/commons/a/af/Tux.png  
6  ls  
7  su - root  
8  happyHack!NG  
9  su - root  
10 whoami  
11 ls  
12 cat coffee.txt  
13 whoami  
14 pwd  
15 date  
16 exit  
17 clear  
18 history  
johnny@ip-10-65-185-8:~$
```

Figura 9 — Histórico de comandos do usuário johnny, expondo a tentativa de troca para root e, na linha seguinte, uma senha digitada por engano como comando.

7.3 Escalonamento para root

Com a senha vazada em mãos, o comando `su - root` foi executado, seguido da senha extraída do histórico. O acesso como root — a conta com privilégios administrativos completos em sistemas Linux — foi obtido com sucesso, encerrando a cadeia de comprometimento: de uma senha anotada em um post-it a controle total do sistema.



```
root@ip-10-65-185-8: ~  
File Edit View Search Terminal Help  
1  ls  
2  vi notes.txt  
3  mv notes.txt coffee.txt  
4  vi cheese.txt  
5  wget -c https://upload.wikimedia.org/wikipedia/commons/a/af/Tux.png  
6  ls  
7  su - root  
8  happyHack!NG  
9  su - root  
10 whoami  
11 ls  
12 cat coffee.txt  
13 whoami  
14 pwd  
15 date  
16 exit  
17 clear  
18 history  
johnny@ip-10-65-185-8:~$ su -root  
su: invalid option -- 'r'  
Try 'su --help' for more information.  
johnny@ip-10-65-185-8:~$ su - root  
Password:  
root@ip-10-65-185-8:~#
```

Figura 10 — Histórico completo do usuário johnny e escalonamento bem-sucedido para root utilizando a senha exposta no histórico de comandos.

Resultado

A cadeia completa de comprometimento — de uma senha em um post-it até acesso root — não

exigiu nenhuma técnica sofisticada de exploração: apenas duas falhas humanas simples (senha fraca observável fisicamente e senha digitada por engano no lugar errado).

8. Comandos Utilizados

Comando	Função
whoami	Exibe o nome do usuário atualmente conectado.
ssh usuario@ip	Estabelece uma conexão remota segura e autenticada com outra máquina.
ls	Lista os arquivos e pastas do diretório atual.
cat <arquivo>	Exibe o conteúdo de um arquivo de texto no terminal.
history	Lista os comandos digitados anteriormente na sessão do usuário.
su - <usuário>	Troca a sessão para outro usuário, mediante senha.

9. Recomendações de Mitigação

- Adotar senhas longas, únicas por serviço e geradas por um gerenciador de senhas, evitando datas, nomes e padrões de teclado previsíveis.
- Habilitar autenticação multifator (MFA) sempre que disponível, reduzindo o impacto de uma senha comprometida.
- Nunca anotar credenciais em locais visíveis fisicamente, como post-its colados em monitores.
- Aguardar o prompt correto antes de digitar uma senha, evitando que ela seja registrada em texto plano no histórico do shell.
- Limpar ou desabilitar o histórico de comandos em sessões sensíveis, e revisar periodicamente arquivos como `.bash_history` em busca de dados expostos.
- Aplicar o princípio do menor privilégio, restringindo o uso de contas administrativas (`root/administrator`) ao mínimo necessário.

10. Conclusão

Este laboratório demonstrou, de ponta a ponta, como falhas simples e humanas — não vulnerabilidades técnicas sofisticadas — costumam ser o elo mais fraco da segurança da informação. Uma senha anotada em um post-it e uma credencial digitada no momento errado foram suficientes para uma cadeia completa de comprometimento, do acesso inicial ao controle total do sistema como `root`.

Esse tipo de exercício reforça a importância, para qualquer profissional de suporte técnico ou segurança, de compreender tanto o lado ofensivo quanto o defensivo dessas falhas: reconhecer os fatores de risco, comunicar boas práticas de autenticação aos usuários e revisar rotineiramente

artefatos como histórico de comandos e permissões de arquivo em ambientes sob sua responsabilidade.